

1. Tình hình an toàn thông tin gần đây

2. Đối tượng an toàn thông tin



3. Khái niệm an toàn thông tin

- Là sự bảo vệ thông tin và các hệ thống thông tin tránh bị truy nhập, sử dụng, tiết lộ, gián đoạn, sửa đổi hoặc phá hoại trái phép nhằm bảo đảm tính nguyên vẹn, tính bảo mật và tính khả dụng của thông tin (72/2013/NĐ-CP)

- Ba tính chất an toàn của thông tin

+ Tính bí mật

+ Tính toàn vẹn

+ Tính khả dụng

\* Tính bí mật

- KN: thông tin chỉ cung cấp cho những người có thẩm quyền

- Nguyên nhân phá vỡ tính bí mật:

+ Nghe lén, xem lén, đọc lén

+ Đánh cắp vật mang

+ Xâm nhập trái phép

+ Sự bất cẩn

+ Gian điệp

\* Tính toàn vẹn

- KN: đảm bảo thông tin không bị thay đổi một cách trái phép hoặc thay đổi không như ý muốn

- Nguyên nhân phá vỡ:

- + Lỗi đạ truyền
- + Lỗi phát sinh khi lưu trữ
- + Tấn công sửa đổi, phá hủy

### \* Tính khả dụng

- KN: đảm bảo khả năng truy cập thông tin, tính năng của hệ thống thông tin mỗi khi ngừng hợp lệ có nhu cầu

- Nguyên nhân phá vỡ:

- + Tấn công DOS, DDoS
- + Cấu hình sai
- + Tính toàn vẹn bị phá vỡ
- + Hỏng hóc
- + Mất điện, thiên tai, hỏa hoạn

- An ninh thông tin là việc bảo đảm thông tin trên mạng không gây phương hại đến an ninh quốc gia, trật tự an toàn xã hội, lợi ích nhà nước, quyền và lợi ích hợp pháp của tổ chức cá nhân ( 72 / 2013 / ND - CP )

## II. Hiểm họa ATTT

### 1. Khái niệm hiểm họa an toàn thông tin

#### \* Hiểm họa

- Hiểm họa ATTT của HTTT là nh khả năng tác động lên TT, HTTT dẫn tới sự thay đổi, hư hại, sao chép, sự ngăn chặn tiếp cận tới TT, tới sự phá hủy hoặc sự ngừng trệ hoạt của vật mạng TT

VD:

#### \* Lỗi hỏng

- Lỗi hỏng của HTTT là nh khiếm khuyết trong chức năng



thành phần nào đó của HTTT mà có thể bị lợi dụng để gây hại cho hệ thống

VD:

- + Không có cơ chế ngăn chặn duyệt mật khẩu
- + Luật lọc của tường lửa không được cập nhật
- + Không có UPS

\* Điểm yếu ≠ Lỗ hổng

- Lỗ hổng

- + Thúc tế đã bị khai thác
- + <https://cve.mitre.org/>
- + CVE = Common Vulnerabilities and Exposures

- Điểm yếu

- + Có thể bị khai thác
- + <https://cwe.mitre.org/>
- + CWE = Common Weakness Enumeration

\* Rủi ro

- Rủi ro của HTTT là khả năng xấu có thể xảy ra đối với hệ thống

- VD:

- + Rủi ro lộ bí mật
- + Rủi ro mất dữ liệu
- + Rủi ro hỏng thiết bị

Phân loại hiểm họa ATTT

- Theo bản chất xuất hiện

- + Hiểm họa tự nhiên: thiên tai, môi trường, âm mưu,
- + Hiểm họa nhân tạo: phá hoại, thao tác sai, ...

- Theo mức độ định trước

- + Hiếm học từ hành động vô ý
- + Hiếm học từ hành động có chủ ý
- Theo nguồn trực tiếp sinh ra
  - + Nguồn sinh trực tiếp là con ng
  - + Nguồn sinh là các phần mềm hợp lệ
  - + Nguồn sinh là các phần mềm trái phép
- Theo vị trí của nguồn sinh ra
  - + Nguồn sinh ra nằm ngoài vùng kiểm soát
  - + Nguồn sinh ra nằm trong vùng kiểm soát
  - + Nguồn sinh có tiếp cận thiết bị đầu cuối
  - + Nguồn sinh nằm ngay trong hệ thống
- Theo mức độ hoạt động của HTTT
  - + Không phụ thuộc vào hoạt động của hệ thống
  - + Chỉ xuất hiện khi hệ thống hoạt động
- Theo mức độ tác động lên HTTT
  - + Hiếm học thụ động, không làm thay đổi cấu trúc, nội dung của hệ thống
  - + Hiếm học tích cực, gây ra nhĩ thay đổi nhất định trong hệ thống

Xác định danh sách hiếm học đối với HTTT là khâu quan trọng trong đảm bảo APTT cho hệ thống, bởi nó cho biết cần phải áp dụng nhĩ biện pháp bảo vệ nào!

### Nguyên tắc đảm bảo APTT

#### 1. Nguyên tắc tính hệ thống

- Các yếu tố, các điều kiện và các nhân tố có quan hệ với nhau, có tương tác với nhau và có biến đổi theo thời gian
- Chồng lại cả nhĩ kênh truy cập trái phép tiềm tàng (chưa biết)



## 2. Nguyên tắc tổng thể

- Các biện pháp phải thống nhất, đồng bộ
- Phải tổ chức phòng ngừa nh - lớp

## 3. Nguyên tắc bảo vệ liên tục

- Đảm bảo ATTT là quá trình liên tục
- Xuyên suốt chu kỳ sống của hệ thống, từ thiết kế cho đến loại bỏ

## 4. Nguyên tắc đầy đủ hợp lý

- Không có an toàn tuyệt đối
- Biện pháp bảo vệ có ảnh hưởng ít nhất đến hoạt động của hệ thống
- Biện pháp bảo vệ thường tốn kém
- Chi phí cho việc bảo vệ không lớn hơn giá trị của hệ thống
- Mục tiêu của bảo vệ là đưa rủi ro về mức chấp nhận được

## 5. Nguyên tắc mềm dẻo hệ thống

- Phân hệ an toàn được thiết lập trong điều kiện có nh - bất định
- Phải cho phép nâng cấp, cập nhật

## 6. Nguyên tắc đơn giản trong sử dụng

- Cơ chế bảo vệ không được gây khó khăn cho ng - dùng hợp lệ

## 7. Nguyên tắc công khai thuật toán và cơ chế bảo vệ

- Biết được thuật toán, cơ chế bảo vệ cũng không thể vượt qua được
- Chính tác giả cũng không thể vượt qua
- Không có nghĩa là phải công khai thuật toán và cơ chế bảo vệ

Phương pháp chung đảm bảo an toàn thông tin

Ngăn cản

Kiểm soát  
truy cập

Mã hóa

Quy chế

Cưỡng chế

Giáo dục

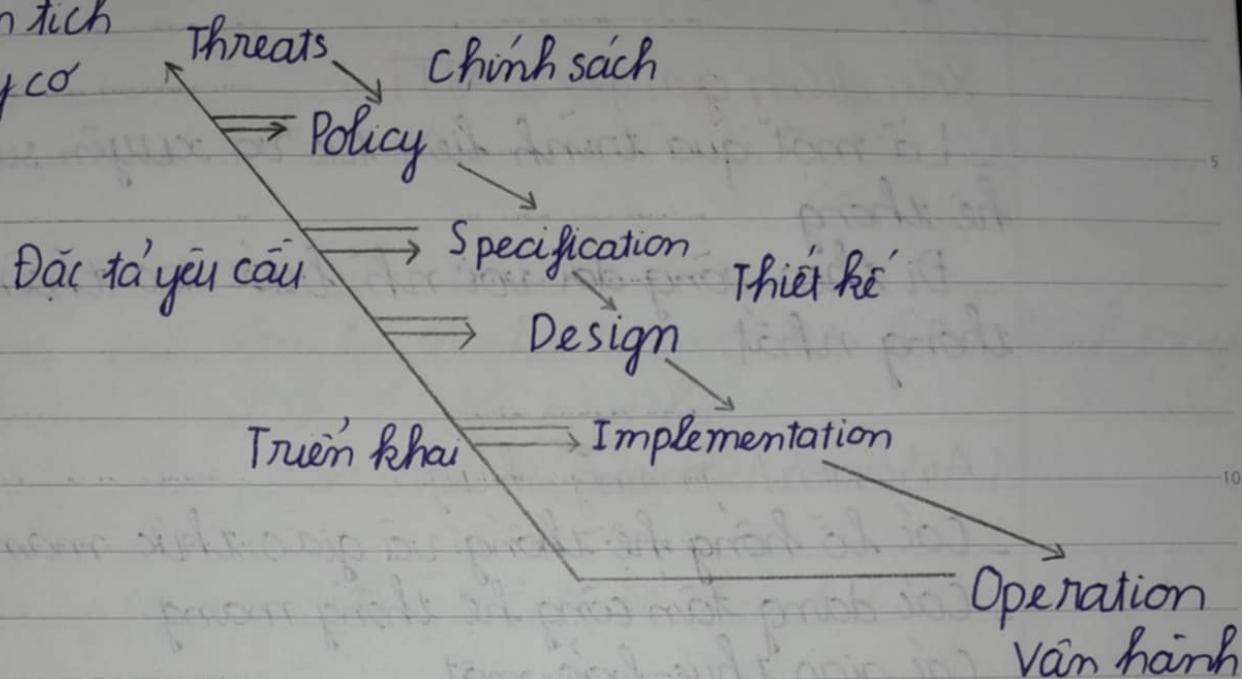
- Ngăn cản: không cho phép tiếp cận khu vực được bảo vệ
- Kiểm soát truy cập: điều khiển, kiểm soát mọi thành phần của hệ thống
- Mật mã (che giấu): biến đổi thông tin về dạng khác
- Quy chế: đưa ra các quy tắc xác định nh việc mà con ng đc làm, k đc làm, phải làm
- Cưỡng chế: gắn liền với quy chế, là việc đưa vào nh cơ chế mà khiến con ng phải thực hiện đúng theo quy tắc đã định
- Giáo dục: tác động lên ý thức, đạo đức con ng
- Phương tiện chính tắc (formal): thực hiện các chức năng bảo vệ theo đúng các thủ tục được xác định trước mà không cần sự can thiệp của con ng
- Phương tiện phi chính tắc (informal): quy định hành



vi của con ng

## B) Giải pháp ATTT

Phân tích  
nguy cơ



Giải pháp an toàn thông tin là một tập hợp bao gồm

### 1) Chính sách về an toàn thông tin

- Nguyên tắc cơ bản về an toàn thông tin bao gồm các yêu cầu và mục tiêu cần đạt được về an toàn thông tin...
- Danh sách các tài sản là tài nguyên thông tin cần bảo vệ, nguy cơ và rủi ro với từng tài sản
- Quyền và nghĩa vụ của các chủ thể có liên quan như: ng sở hữu, ng quản trị, ng sử dụng,

### 2) Các biện pháp bảo vệ an toàn thông tin gồm:

- Biện pháp kỹ thuật (áp dụng công nghệ)
- Biện pháp về thủ tục (quy định trong quản lý)

### 3) Quản lý vận hành và cập nhật giải pháp

- Hướng dẫn, đào tạo cho các thành viên thực hiện đúng các biện pháp
- Giám sát việc thực hiện và lưu lại các dữ liệu
- Phân tích dữ liệu để đánh giá kết quả vận hành

S

Bài toán bảo mật truyền tin

S cần truyền bản tin M cho R trong điều kiện kênh truyền tin giữa S và R có thể bị tấn công bởi A

Mục tiêu: Đảm bảo tính bí mật của bản tin M

Giải pháp:

Sử dụng phép mã hoá E biến M thành C

Trong sơ đồ, khoá K là tham số quan trọng điều khiển quá trình mã hoá và giải mã

Kẻ tấn công A được xem như biết phép mã hoá E và giải mã D nhưng không biết khoá K

Do đó, khoá K giữ một vai trò quyết định đối với mục tiêu bảo vệ tính bí mật của giải pháp mật mã

Một số thuật ngữ và ký hiệu viết tắt

M: bản rõ (plaintext)

C: bản mã (ciphertext)

E: phép mã hoá (encryption)

D: phép giải mã (decryption)

K: khoá (Key)

S: người gửi (Sender)

R: người nhận (Receiver)



- Điều chỉnh lại giải pháp để đảm bảo mục tiêu và đáp ứng các thay đổi

### Xây dựng giải pháp ATTT

- Là một quá trình liên tục và xuyên suốt sự tồn tại của hệ thống

- Đi theo vòng đời với nh. bước tạo thành một quy trình thống nhất

### An ninh mạng chuyên về

- Các lỗ hổng hệ thống và giao thức mạng
- Các dạng tấn công hệ thống mạng
- Các giao thức bảo mật

## Chương 2: Cơ sở mật mã

### 2.1 Các khái niệm cơ bản

- Mật mã (Cryptology) là lĩnh vực nghiên cứu về các phương pháp mã hoá thông tin

- Thuật ngữ Cryptology xuất phát từ krypto, trong tiếng Hy Lạp nghĩa là che đậy

- Mật mã bao gồm 2 lĩnh vực con

+ Lập mã (Cryptography) sáng tạo kỹ thuật mã hoá để bảo vệ tính bảo mật của thông tin

+ Thăm mã (Cryptanalysis) nghiên cứu các kỹ thuật phân tích để phá vỡ cơ chế lập mã, tiết lộ bí mật của thông tin đã được mã hoá

### A) Mô hình truyền tin mật mã cơ bản



Hệ mật mã (cryptosystem): là một hệ thống bao gồm phép mã hoá  $E$ , phép giải mã  $D$ , cách thức sinh khoá  $K$ , cách quản lý và phân phối khoá cho các ng gửi  $S$  và ng nhận  $R$ .  
 Căn cứ đặc tính và cách tổ chức quản lý khoá  $K$ , có hai loại hệ mật mã khác nhau

Hệ mật mã khoá đối xứng (

Hệ mật mã khoá công khai (

B. Độ bảo mật của hệ mật mã

- Độ bảo mật (hay độ an toàn) của hệ mật mã là khả năng đứng vững của hệ mật mã trứ nguy cơ tấn công thám mã

- Mục tiêu thám mã: thu thập dữ liệu, phân tích và truy tìm ra khoá  $K$

- Mức độ bảo mật được đánh giá thông qua

+ Chứng minh bằng toán học

+ Thử nghiệm tấn công thám mã vào hệ mật mã

- Độ an toàn được xác định nếu:

+ Chứng minh được độ khó của mật mã thoả mãn điều kiện đặt ra

+ Thử nghiệm tấn công mà không phá vỡ đc mật mã trong điều kiện cho phép

Các mô hình đánh giá mức độ bảo mật hiện nay

1. Bảo mật vô điều kiện (tuyệt đối): kẻ tấn công dù thu thập được tất cả bản mã và bản rõ trước đây, đồng thời có năng lực tính toán vô tận cũng không thể thám mã và truy ra được khoá  $K$

2. Bảo mật chứng minh được: chứng minh đc cụ thể mức độ phức tạp của việc thám mã tương đương độ phức tạp của một bài toán khó đã biết



3. Bảo mật thực tế: Không chứng minh bằng toán học nhưng có thể đứng vững trứ mọi thử nghiệm tấn công thám mã trong thực tế

Ví dụ: sau khi thử nghiệm cho thấy siêu máy tính mạnh nhất với các dạng thám mã từ thấp đến cao cần khoảng 10000 năm mới phá vỡ được mật mã.

Do đó, có thể xem như đạt độ an toàn thực tế

- Mô hình số 1 chỉ mang tính tham chiếu vì không thực tế
- Mô hình số 2 phù hợp với các hệ mật mã dựa trên lý thuyết số (toán học)
- Mô hình số 3 mang tính thực nghiệm và phù hợp với mọi hệ mật mã

Các tiêu chí lựa chọn hệ mật mã

1) Mức độ an toàn tin cậy và chấp nhận được

2) Có hiệu quả trong ứng dụng thực tế:

- Có thể cài đặt phép mã hoá và giải mã trên hardware / software

- Tốc độ xử lý của thuật toán mã hoá đạt yêu cầu thực tế

## 2.2. Một số hệ mật mã cổ điển

Lịch sử mật mã được chia thành 2 thời kỳ

- + Mật mã cổ điển: xuất hiện từ trước Công nguyên cho đến cuối thế kỷ 19

- + Mật mã hiện đại: trở thành 1 ngành khoa học chính thức từ giữa thế kỷ 20

→

Gán cho mỗi chữ cái 1 giá trị số tương ứng

A 0

B 1

C 2

D 3

E 4

...

Z 25

Công thức mã hoá

$$c = (m + 3) \bmod 26$$

m: kí tự của bản rõ M

c: kí tự của bản mã C

Mã hoá và giải mã Caesar

Mã hoá bản tin "HELLO IT WORLD" bằng mã Caesar (K = 3)

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

D E F G H I J K L M N O P Q R S T U V W X Y Z A B C

Mã hoá bản tin "HELLO IT WORLD" bằng mã Caesar (K = 3)

"HELLO IT WORLD" → "KHOOR LW ZRUOG"

Mã hoá bản tin "SECURITY" với mã Caesar khi K = 15

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

⇒ "SECURITY" → "

Thăm mã



### A) Mã hoá bằng thể tổng quát

- Cách mã hoá: thay thế kí tự trong bảng mã gốc bằng 1 kí tự tương ứng trong một bảng thể

Ví dụ: Cho bản rõ M = "A DAY", sử dụng bảng thể dưới đây thu được bản mã

C = "FTEP"

Bảng gốc      A      B      C      D      ...      W      X      Y      Z

Bảng thể      F      G      N      T      ...      U      K      P      L

- Mỗi một bảng thể chính là một khoá K để mã hoá và giải mã

- Với bảng chữ cái gồm 26 kí tự, tổng số khoá K có thể có là bao nhiêu?

$$26 \times 25 \times 24 \times \dots \times 2 \times 1 = 26!$$

### B. Mã Caesar

- Do hoàng đế La Mã Julius Caesar tạo ra

- Bảng thể là bảng chữ cái đã dịch các kí tự sang trái 3 vị trí

Bảng gốc      A      B      C      D      ...      W      X      Y      Z

Bảng thể      D      E      F      G      ...      Z      A      B      C

### Đặc điểm mã Caesar

- Mã Caesar được gọi là mã cộng (additive cipher) theo cách như sau

### Chương 3: Hệ mật mã khóa đối xứng

#### 3.1. Đặc điểm về nguyên lý

##### - Hệ mật mã khóa đối xứng

- Hệ mật mã đối xứng là một hệ thống mật mã trong đó một khóa được sử dụng cho cả quá trình mã hóa và giải mã

##### A. Đặc điểm

- Mã hóa và giải mã sử dụng chung 1 khóa  $K$ , do đó khóa  $K$  phải giữ bí mật
- Mã hóa dạng khối dữ liệu nhị phân (binary)
- Phù hợp để mã hóa dữ liệu trong máy tính với kích thước dữ liệu tùy ý

##### \* Mã khối (Block Cipher)

Là một loại hệ thống mã hóa đối xứng, trong đó dữ liệu được chia thành các khối cố định (thường là 64 bit, 128, 256 bit) và mỗi khối được mã hóa riêng lẻ = một khóa bí mật

##### - Nguyên lý thiết kế mã khối:

Theo Shannon có 2 nguyên tắc cơ sở để thiết kế mã khối với độ bảo mật cao:

+ Tính khuếch tán: Mỗi bit của bản rõ sẽ tác động đến các

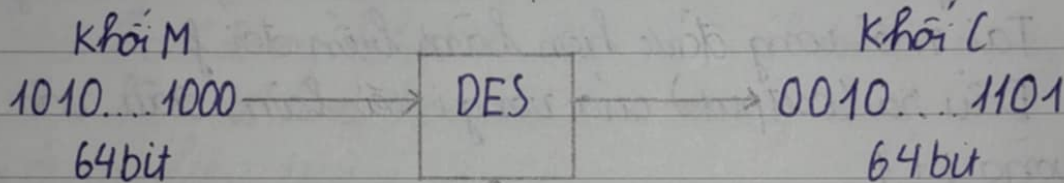


- + Là thuật toán mã khối, độ dài mỗi khối 64 bit
- + Khóa ban đầu có độ dài 64 bit. Tuy nhiên chỉ có 56 bit được sử dụng thực tế. Các bit còn lại kiểm tra tính chẵn lẻ của khóa

- + Sử dụng cấu trúc Feistel
- + Xuất ra bản mã 64 bit
- + Thực hiện 16 vòng

#### A) Khối dữ liệu của DES

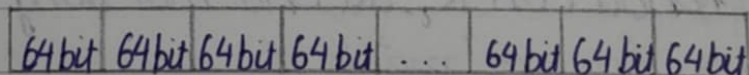
- Đầu vào là khối dữ liệu M (bản rõ) 64 bit
- Khóa K 64 bit gồm 56 bit sử dụng và 8 bit parity
- Đầu ra là khối dữ liệu C (bản mã) 64 bit



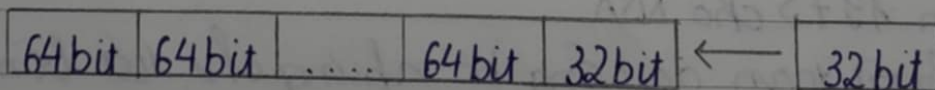
Khóa K: 0101...0001

#### \* Padding

- Dữ liệu gốc cần mã hóa được chia thành các khối 64 bit



- Nếu dữ liệu gốc không phải số chẵn lần 64 bit thì cần áp dụng cơ chế padding để bổ sung thêm dữ liệu vào khối cuối cùng.



#### B) Thuật toán lưu đồ

Thuật toán mã hóa DES là một quy trình gồm các pha theo trình tự sau:

bit của bản mã, hay nói cách khác, một bit của bản mã sẽ chịu của tất cả các bit của trong bản rõ. Vì làm như vậy & nhằm làm giảm tối đa mối liên quan giữa bản rõ và bản mã, ngăn chặn việc suy ngược lại.

+ Tính xáo trộn: làm phức tạp hoá mối liên hệ giữa bản mã và khoá gây khó khăn cho kẻ thám mã cố ý định tìm quy luật để phá mã.

2) Kỹ thuật: Thực hiện 1 chuỗi các phép biến đổi dữ liệu bao gồm hoán vị và thay thế kết hợp nhau.

3) Quy trình mã hoá được thiết kế với nh vòng lặp.

Tại mỗi vòng thực hiện hàm biến đổi  $f$ .

Đầu ra (output) của vòng  $i$  sẽ làm đầu vào (input) cho vòng  $i + 1$ .

Vòng  $i$  sử dụng 1 khoá con  $K_i$  sinh ra từ khoá gốc  $K$  qua 1 quy trình sinh khoá.

4) Giải mã là quy trình ngược với mã hoá.

Sử dụng cùng sơ đồ, cùng số vòng và hàm  $f$ .

Các khoá con  $K_i$  đã cho mỗi vòng được áp dụng theo thứ tự ngược lại với mã hoá.

### 3.2 Chuẩn mã mã DES

- DES (Data Encryption Standard) do IBM phát triển vào năm 1973 cho NSA.

- Thuật toán được công bố nhưng chi tiết bên trong thiết kế được NSA giữ bí mật.

- 1977 được công nhận thành tiêu chuẩn mã hoá và được sử dụng rộng rãi mặc dù còn nhiều tranh cãi.

- Đặc điểm của thuật toán DES:



Pha khởi tạo: phép hoán vị khởi đầu IP

Pha mã hoá: Thực hiện 16 vòng lặp biến đổi dữ liệu cũng với khoá K

Pha kết thúc: phép hoán vị kết thúc FP (lã đảo ngược của IP)

## Chương 4: Hệ mật mã khóa công khai

### 1. Giới thiệu tổng quan

Hệ mật mã khóa công khai là một thành tựu lớn của mật mã hiện đại

Thay đổi nguyên tắc truyền thống của mật mã

Giải quyết bài toán chia sẻ và quản lý khóa của mật mã khóa đối xứng

Tạo ra giải pháp chữ ký số (chữ ký điện tử) hiện được áp dụng trong hầu hết các dịch vụ và ứng dụng CNTT

#### A) Hoàn cảnh ra đời

- Năm 1976, Diffie và Hellman đưa ra ý tưởng công khai thông tin về khóa mã vẫn đảm bảo tính bí mật của hệ mật mã

- Năm 1977, Rivest, Shamir và Adleman phát minh hệ mật mã khóa công khai RSA

- Các hệ mật mã khác xuất hiện sau đó: Rabin, El-Gammar, Elliptic Curve

#### B) Đặc điểm

- Trong hệ mật mã khóa công khai (PKC), mỗi chủ thể cần sở hữu 1 cặp khóa

· Khóa công khai  $K_E$  (public key)

· Khóa riêng  $K_D$  (private key)

- Khóa công khai có thể phổ biến cho tất cả cũng biết

- Khóa riêng phải được chủ thể sở hữu giữ bí mật

Cặp khóa  $K_D$  và  $K_E$

·  $K_E \neq K_D$  nhưng có mối quan hệ 1-1

· Mã hóa  $M$  bằng  $K_E$  chỉ giải mã bằng  $K_D$  và ngược lại

$$M = D(K_D, E(K_E, M)) \quad (1)$$

$$M = D(K_E, E(K_D, M)) \quad (2)$$



Công thức (1) là cơ sở để bảo mật dữ liệu

Công thức (2) là cơ sở để tạo ra chữ kí số (chữ kí điện tử)

C) Nguyên tắc thiết kế hệ PKC

Sử dụng cơ chế hàm  $f$  một chiều có "cửa lật" với tính chất sau:

Với mọi đầu vào, tính  $Y = f(X)$  là dễ

Biết  $Y$ , rất khó để tính ngược  $X$  trừ khi biết "Cửa lật"

"Cửa lật" chính là **khóa riêng** được giữ bí mật để có thể giải mã bằng hàm ngược  $f^{-1}$   $X = f^{-1}(Y)$

Không biết cửa lật để giải mã, việc phá mã trở nên vô cùng khó khăn

So sánh

Hệ mật mã khóa công khai

- Mỗi bên truyền tin sở hữu 1 cặp khóa khác nhau

- Mã hoá bằng 1 khóa và giải mã bằng khóa kia

- Một khóa có thể trao đổi công khai

- Ứng dụng trong chữ ký điện tử

- Hàm mã hoá là hàm toán học 1 chiều và có cửa lật

Hệ mật mã khóa đối xứng

- Cả hai bên cũng sở hữu 1 khóa

- Mã hoá và giải mã cũng 1 khóa

- Cần 1 kênh bí mật an toàn để trao đổi khóa

- Không thể sử dụng trong chữ ký điện tử

- Hàm mã hoá là hàm biến đổi với hoán vị và thay thế

**Nhắc lại lý thuyết số**

1. Phép chia modulo:

- Phép chia modulo là phép chia lấy phần dư

VD:  $27 \bmod 8 = 3$ ,  $35 \bmod 9 = 8$

- Một cách tổng quát:

$$a \bmod n = r \text{ với } a \geq 0; n > 0; 0 \leq r \leq n-1$$

- Nếu hai số  $a, b$  có cùng số dư trong phép chia cho  $n$  thì ta nói rằng  $a$  và  $b$  là đồng dư trong phép chia modulo cho  $n$ , phép so sánh đồng dư được ký hiệu bằng dấu  $\equiv$ :

$$a \equiv b \pmod{n} \text{ hay viết tắt là } a \equiv b \bmod n$$

VĐ với  $n = 4$  ta có 4 lớp tương đương sau:

$$\{0, 4, 8, 12, 16, \dots\}$$

$$\{1, 5, 9, 13, 17, \dots\}$$

$$\{2, 6, 10, 14, 18, \dots\}$$

$$\{3, 7, 11, 15, 19, \dots\}$$

2. Một số t/c của phép modulo

(Cho  $a, b$  và  $n$  là các số nguyên, phép modulo có các t/c

$$a) (a + b) \bmod n = [(a \bmod n) + (b \bmod n)] \bmod n$$

$$b) (a - b) \bmod n = [(a \bmod n) - (b \bmod n)] \bmod n$$

$$c) (a \times b) \bmod n = [(a \bmod n) \times (b \bmod n)] \bmod n$$

3. Ước số

- Nếu  $a \bmod n = 0$  (viết cách khác  $a \equiv 0 \pmod{n}$ ) thì có nghĩa là  $a$  chia hết cho  $n$ , hay  $n$  là ước số của  $a$

- Ước số

Thuật toán Euclid tìm  $\text{GCD}(A, B)$



VD: Tìm  $\text{GCD}(2740, 1760)$

| $q$ | $n_1$ | $n_2$ | $n$ |
|-----|-------|-------|-----|
| 1   | 2740  | 1760  | 980 |
| 1   | 1760  | 980   | 780 |
| 1   | 980   | 780   | 200 |
| 3   | 780   | 200   | 180 |
| 1   | 200   | 180   | 20  |
| 9   | 180   | 20    | 0   |
|     | 20    | 0     |     |

$\Rightarrow \text{gcd}(2740, 1760) = 20$

Nguyên tố cùng nhau

- Hai số nguyên  $a, b \in \mathbb{Z} \setminus \{0\}$  đc gọi là nguyên tố cùng nhau nếu  $\text{gcd}(a, b) = 1$

VD:  $(5, 8), (9, 14)$  là các cặp nguyên tố cùng nhau

Phần tử nghịch đảo của phép nhân modulo

- Nếu hai số nguyên  $a$  và  $n$  nguyên tố cùng nhau, thì tồn tại số nguyên  $w$  sao cho:

$$aw \equiv 1 \pmod{n}$$

Ta gọi  $w$  là phần tử nghịch đảo của  $a$  trong phép modulo cho  $n$  và ký hiệu là  $a^{-1}$

### Nghịch đảo nhân

- Nếu tồn tại 1 số  $b \in \mathbb{Z}_n$  sao cho  $ab \equiv 1 \pmod{n}$  thì  $b$  được gọi là nghịch đảo nhân của  $a$  modulo  $n$

Ký hiệu:

$$b = a^{-1} \pmod{n}$$

- Điều kiện để số  $a$  có nghịch đảo nhân khi và chỉ khi  $\gcd(a, n) = 1$

VD:  $a = 22, n = 25$

$\gcd(22, 25) = 1 \rightarrow a$  có nghịch đảo nhân

$$8 = 22^{-1} \pmod{25} \text{ vì } 8 \cdot 22 = 176 = 1 \pmod{25}$$

$\rightarrow 8$  là nghịch đảo nhân của 22 modulo 25

### Thuật toán Euclid mở rộng

VD: tìm  $550^{-1} \pmod{1759}$

Bước 1: Kiểm tra  $\gcd(550, 1759)$ . Nếu  $\gcd \neq 1$  thì kết luận không tồn tại nghịch đảo

Bước 2: Lập bảng

Trong đó

$$q_i = \frac{r_{i-2}}{r_{i-1}}$$

$$r_i = r_{i-2} \bmod r_{i-1}$$

$$y_i = y_{i-2} - y_{i-1} \cdot q_i$$

$y_0 = 0, y_1 = 1$  là các giá trị khởi tạo

| $r$  | $q$ | $y$  |
|------|-----|------|
| 1759 |     | 0    |
| 550  |     | 1    |
| 109  | 3   | -3   |
| 5    | 5   | 16   |
| 4    | 21  | -339 |
| 1    | 1   | 355  |

### Tính lũy thừa nhanh

Ví dụ: tính  $3^{644} \pmod{645}$



B1. Biểu diễn 644 dưới dạng nhị phân:  $644 = (1010000100)_2$

Suy ra  $644 = 2^9 + 2^7 + 2^2$

Từ đó suy ra  $3^{644} = 3^{512} \cdot 3^{128} \cdot 3^4$

B2: Lập bảng

B3: Từ bảng suy ra kết quả

$$3^{644} = 111 \cdot 396 \cdot 81 \bmod 645$$

$$= 36$$

| i | $a_i$ | $3^{2^i}$                         |
|---|-------|-----------------------------------|
| 0 | 0     | $3 \bmod 645 = 3$                 |
| 1 | 0     | $3^2 \bmod 645 = 9$               |
| 2 | 1     | $3^4 \bmod 645 = 81$              |
| 3 | 0     | $3^{2^3} = 81^2 \bmod 645 = 111$  |
| 4 | 0     | $3^{2^4} = 111^2 \bmod 645 = 66$  |
| 5 | 0     | $3^{2^5} = 66^2 \bmod 645 = 486$  |
| 6 | 0     | $3^{2^6} = 486^2 \bmod 645 = 126$ |
| 7 | 1     | $3^{2^7} = 126^2 \bmod 645 = 396$ |
| 8 | 0     | $3^{2^8} = 396^2 \bmod 645 = 81$  |
| 9 | 1     | $3^{2^9} = 81^2 \bmod 645 = 111$  |

## Thuật toán mã hoá RSA

1.

Thuật toán mã hoá RSA thoả mãn 5 yêu cầu của một hệ mã hiện đại:

1. Độ bảo mật cao (nghĩa là để giải mã được mà không biết khoá mật thì phải tốn hàng triệu năm)
2. Thao tác nhanh (thao tác mã hoá và giải mã tốn ít thời gian)
3. Dễ dàng thực hiện
4. Có ứng dụng rộng rãi
5. Có thể dùng để xác định chủ nhân (dùng làm ký chữ ký điện tử)

## 2. Mô tả hoạt động

Thuật toán RSA có hai khoá:

Bước 4: tính  $d = e^{-1}$  bằng cách dùng thuật toán Euclide

Bước 5:

- $n$  và  $e$  làm khoá công khai (public key)
- $d$  làm khoá bí mật (private key)

Bước 4: Dùng thuật toán Euclide tìm ra  $d = 503$

Bước 5:

- khoá công khai  $n = 943$  và  $e = 7$
- khoá bí mật  $d = 503$

Ví dụ RSA: Để minh họa ta sẽ thực hiện một ví dụ về mã hoá RSA với kích thước khoá là 6 bit

1. Chọn  $p = 11$  và  $q = 3$ , do đó  $N = pq = 33$  ( $2^5 = 32 < 33 < 64 < 2^6$ )
2.  $\Phi(n) = (p-1)(q-1) = 20$
3. Chọn  $e = 3$  nguyên cùng nhau với  $n$
4. Tính nghịch đảo của  $e$  trong phép modulo  $n$  được  $d = 7$  ( $3 \cdot 7 = 21$ )
5. Khóai công khai  $K_U = (e, N) = (3, 33)$ . Khóai bí mật  $K_R = (d, N) = (7, 33)$

Theo phương án 1 (mã hoá bảo mật):

6. Mã hoá bản rõ  $M = 15$ :

$$C = M^e \bmod N = 15^3 \bmod 33 = 9 \text{ (vì } 15^3 = 3375 = 102 \cdot 33 + 9)$$

7. Giải bản mã  $C = 9$ :

$$\bar{M} = C^d \bmod N = 9^7 \bmod 33 = M \text{ (vì } 9^7 = 4782969 = 144938 \cdot 33 + 15)$$





- Khóa công khai (Public key):  
được công bố rộng rãi cho mọi  
ngi và được dùng để mã hóa

- Khóa bí mật (Private key):  
Chỉ thông tin được mã hóa  
bằng khóa công khai chỉ có  
thể được giải mã bằng khóa  
bí mật tương ứng.

## 2.1 Tạo khóa

### Lý thuyết

Bước 1: Chọn ngẫu nhiên hai số nguyên tố  
lớn ngẫu nhiên  $p$  và  $q$   
Bước 2: tính  $n = p * q$  và  $\phi(n)$   
 $\phi(n) = (p-1)(q-1)$   
Bước 3: Chọn một số nguyên ngẫu nhiên  $e$   
( $0 < e < \phi(n)$ ) sao cho  $\text{UCLN}(e, \phi(n)) = 1$

### Ví dụ

Bước 1: Chọn số 23 và 41  
(hai số này là 2 số nguyên tố)  
Bước 2:  $n = 23 * 41 = 943$   
 $\phi(n) = 22 * 40 = 880$   
Bước 3:  
Chọn  $e = 7$  vì  $\text{UCLN}(7, 880) = 1$

+ Khoa công khai dùng để thẩm định CKS  $\rightarrow$  xác thực

## D. Hàm băm mật mã

- Là 1 hàm biến đổi

Input: bản tin  $M$  có độ dài bất kỳ

Output: chuỗi bit  $h$  có kích thước xác

$$h = H(M)$$

### Tính chất

(1) Từ giá trị băm  $h$ , không thể xác định bản tin gốc  $M$

$\rightarrow$  tính chất một chiều

(2) Nếu sửa đổi bản tin  $M$ , giá trị băm thu được cũng sẽ thay đổi  $\rightarrow$  tính toàn vẹn

(3) Gần như không thể tìm được hai bản tin khác nhau có cùng một giá trị băm  $h \rightarrow$  tính không xung đột

$$M' \neq M \Leftrightarrow H(M') \neq H(M)$$

### \* Chữ ký để làm gì?

Chữ ký nhằm xác nhận vai trò trách nhiệm của chủ thể lên một văn bản

### \* Chữ ký số

- Là 1 ứng dụng quan trọng của hệ mật mã PKC
- Được sử dụng trong các giao dịch số hoá trực tuyến, thay thế cho giao dịch qua giấy tờ truyền thống
- Sử dụng chữ ký số ngày

### Tạo chữ ký số



### 3. Độ an toàn mã hoá RSA

- Độ an toàn của hệ thống RSA dựa trên bài toán phân tích số nguyên lớn thành tích của các thừa số nguyên tố
- Vì vậy muốn xây dựng hệ RSA an toàn thì  $n = p \cdot q$  phải là một số đủ lớn, để không có khả năng phân tích nó về mặt tính toán. Để đảm bảo an toàn nên chọn các số nguyên tố  $p$  và  $q$  từ 100 chữ số trở lên
- Dưới đây là bảng thời gian phân tích mã RSA.

| Số các chữ số trong số được phân tích | Thời gian phân tích   |
|---------------------------------------|-----------------------|
| 50                                    | 4 giờ                 |
| 75                                    | 104 giờ               |
| 100                                   | 74 năm                |
| 200                                   | 4000 năm              |
| 300                                   | 500000 năm            |
| 500                                   | $4 \cdot 10^{25}$ năm |

### 4. Ứng dụng của RSA vào chữ ký điện tử

- Thông tin truyền đi trên mạng cũng cần thiết phải được xác nhận ng gửi
- Các văn bản truyền trên mạng (dưới dạng số hoá) cần phải có chữ ký của ng gửi để xác nhận trách nhiệm của ng gửi.
- Chữ ký dùng ở đây là một dãy bit và được gọi là "chữ ký điện tử".
- Mỗi ng cần 1 cặp khoá gồm khoá công khai & khoá bí mật
- + Khoá bí mật dùng để tạo chữ ký số (CKS)

Bài tập

- 1) Tìm cặp khóa bí mật và công khai với  $p = 7$  và  $q = 19$ .  
Thực hiện mã hóa và giải mã với  $M = \text{HELLO}$  đảm bảo tính bí mật, tính toàn vẹn / chứng thực và cá hai
- 2) Demo thuật toán RSA trên CRYPTOL2

1)

$p = 7, q = 19$  do đó:

B<sub>1</sub>  $N = p * q = 7 * 19 = 133$

B<sub>2</sub>  $\Phi(n) = (p-1)(q-1) = 6 * 18 = 108$

B<sub>3</sub> Chọn  $e = 5$  (ngẫu nhiên) vì  $\text{UCLN}(5, 108) = 1$

B<sub>4</sub>: Tìm  $d$  sao cho

$$(d, e) \bmod \Phi(n) = 1 \text{ tức}$$

$$(d, 5) \bmod 108 = 1$$

Vì  $\text{UCLN}(5, 108) = 1$

|     |     |                |
|-----|-----|----------------|
| $x$ | $y$ | $xy \bmod 108$ |
| 108 | 0   | 0              |
| 5   | 1   | 5              |
| 3   | 21  | -21            |
| 2   | 1   | 22             |
| 1   | 1   | -43            |

$-43 \bmod (108) = 65$   
 $\Rightarrow d = 65 = e^{-1}$

B<sub>5</sub>: Thông điệp HELLO

$$H = 7$$

$$E = 4$$

$$L = 11$$

$$L = 11$$

$$O = 14$$

Mã hóa

$$C = M^e \bmod n$$

$$7^5 \bmod 133 = 49$$



Thông điệp dữ liệu

Hầm băm

Khởi bí mật

Bấm

tóm lược

Mã hóa

Gắn với  
thông điệp dữ liệu

Thông điệp dữ  
liệu đã ký số

Thăm định chữ ký số

Tách

Thông điệp dữ  
liệu đã ký số

Giải mã

Chữ ký số

Thông điệp  
dữ liệu

Hầm băm

Giải mã được?

Bấm  
tóm lược

Bấm  
tóm lược

K' đúng ng gửi

Giống nhau?

Nội dung thông  
điệp toàn vẹn

Nội dung thông  
điệp bị thay đổi

$$4^5 \bmod 133 = 93$$

$$11^5 \bmod 133 = 121$$

$$14^5 \bmod 133 = 105$$

$$\Rightarrow [49, 93, 121, 121, 105]$$

$$B_6: M' = C^d \pmod{n}$$

$$M'_H = 49^{65} \bmod 133 = 7$$

$$M'_E = 93^{65} \bmod 133 = 4$$

$$M'_L = 121^{65} \bmod 133 = 11$$

$$M'_O = 105^{65} \bmod 133 = 14$$

$$\Rightarrow [7, 4, 11, 11, 14]$$

$$65 = 1000001$$

| i | $a_i$ | $49^{2^i}$           |
|---|-------|----------------------|
| 0 | 1     | $49 \bmod 133 = 49$  |
| 1 | 0     | $49^2 \bmod 133 = 7$ |
| 2 | 0     | $7^2 \bmod 133 = 49$ |
| 3 | 0     | $49^2 \bmod 133 = 7$ |
| 4 | 0     | $7^2 \bmod 133 = 49$ |
| 5 | 0     | $49^2 \bmod 133 = 7$ |
| 6 | 1     | $7^2 \bmod 133 = 49$ |

$$\Rightarrow m = (49 \times 49) \bmod 133 = 7$$

### 1) Khái niệm mã độc

- Mã độc (Malware) là nhữn chương trình máy tính được tạo ra với mục đích làm hại đến tính bí mật, tính toàn vẹn hoặc tính sẵn sàng của dữ liệu, ứng dụng và hệ điều hành của hệ thống

- Mã độc (malware) là nhữn chương trình máy tính được tạo ra với mục đích xấu



## \* Phân loại mã độc

### - Căn cứ vật chủ:

+ Logic Bomb: Mã độc được chèn vào một chương trình hợp pháp và chỉ kích hoạt khi điều kiện nào đó xảy ra (ví dụ: đến một ngày cụ thể).

+ Trojan (Trojan Horse): Ẩn mình trong phần mềm hợp pháp, đánh lừa nạn nhân cài đặt, sau đó thực hiện hành vi độc hại như đánh cắp dữ liệu.

+ Backdoor: Tạo lỗ hổng cho hacker truy cập từ xa vào hệ thống mà không cần xác thực.

+ Exploit: Tận dụng lỗ hổng phần mềm / hệ điều hành để xâm nhập, chiếm quyền điều khiển hệ thống.

+ Virus: Lan bằng cách gắn mã độc vào file hợp pháp (vật chủ), khi file đó được mở thì virus thực thi và lan rộng.

### - Lã phần mềm độc lập:

+ Worm (Sâu máy tính): Tự nhân bản và lan truyền qua mạng mà không cần nạn nhân can thiệp hay vật chủ. Thường gây nghẽn mạng hoặc làm sập hệ thống.

+ Zombie: Máy tính bị chiếm quyền kiểm soát và trở thành "máy ma" trong mạng botnet, thực hiện lệnh từ hacker mà nạn nhân không biết.

## \* Mục đích của mã độc

- Thu thập dữ liệu trên máy tính

- Ăn cắp thông tin như mật khẩu, mã bảo mật thẻ tín dụng

- Nghe lén thông tin như chụp màn hình, ghi âm, quay màn hình, keylogger.



- Sử dụng máy tính của nạn nhân để tạo một mạng botnet phục vụ cho các tấn công DDOS.
- Sử dụng máy tính của nạn nhân để phát tán thư rác.
- Sử dụng tài nguyên trên máy nạn nhân (để "đào" Bitcoin).
- Mã hóa dữ liệu và đòi tiền chuộc.
- Phá hủy dữ liệu trên máy nạn nhân.
- Lạm dụng thiết bị phần cứng (Chernobyl, Stuxnet)

## 2. Cách lây nhiễm mã độc

### - Cài đặt trực tiếp:

- + Cho ng khác mượn máy tính, smartphone
- + Rời khỏi máy tính, smartphone mà không khoá hệ thống
- + Máy bị nhiễm mã độc từ nhà sản xuất

### - Phần mềm lậu, bị khoá:

- + Ng bị khoá thường là thành viên của những nhóm cracker, hacker.
- + Phần mềm bị khoá thường bị những mã độc để phục vụ mục đích của tin tặc.
- + Khi sử dụng nh phần mềm như thế, mã độc sẽ phát tán vào máy và lây lan.

### - Qua thiết bị lưu trữ di động:

- + Khi cắm USB, thẻ nhớ, vào máy bị nhiễm mã độc, chúng sẽ bị nhiễm.
- + Cắm USB, thẻ nhớ, đã bị nhiễm vào máy khác, mã độc có thể được kích hoạt và lây nhiễm vào máy đó.
- + Kích hoạt tính năng autorun, động của ng dùng

### - Khai thác lỗi phần mềm:

- + Phần mềm: hệ điều hành, phần mềm văn phòng,



trình duyệt web, phần mềm chơi nhạc và video, game, ...

+ ) Nhì phần mềm có lỗi !

+ ) Hacker tạo ra nhì dấu vào đặc biệt cho phần mềm ( văn bản, trang web, file , gói tin ... ) trong đó có mã độc

+ ) Khi phần mềm xử lý dấu vào đặc biệt đó thì mã độc đc thực thi.

### 1. Nhân tố xác thực

- Định danh là việc gán định danh cho ng dùng và kiểm tra sự tồn tại của định danh đó.

Qua